MITRE ATLAS | AML.CS0049 - Supply Chain Compromise via Poisoned ClawdBot Skill

Entry Information

ID:
AML.CS0049

Type:
Case-Study

Name:
Supply Chain Compromise via Poisoned ClawdBot Skill

URL:
https://atlas.mitre.org/studies/AML.CS0049/

Incident Date:
2026-01-26

Target:
ClawdBot (now OpenClaw)

Actor:
Jamieson O'Reilly

Description

A security researcher demonstrated a proof-of-concept supply chain attack using a poisoned ClawdBot Skill shared on ClawdHub, a Skill registry for agents. The poisoned Skill contained a prompt injection that caused ClawdBot to execute a shell command that reached the researcher's server. Although the researcher here used this access simply to warn users about the danger, they could have instead delivered a malicious payload and compromised the user's system. The security researcher recorded 16 different users who downloaded and executed the poisoned Skill in the first 8 hours of it being published on ClawdHub.

Attack Procedure:
[AML.T0017] Develop Capabilities: The researcher created a simple web server to log requests.
[AML.T0008.002] Domains: The researcher registered the domain `clawdhub-skill.com` to host their web server.
[AML.T0065] LLM Prompt Crafting: The researcher crafted a prompt injection designed to cause Claude Code to execute a `curl` command to the researcher's `clawdhub-skill.com` domain.
[AML.T0104] Publish Poisoned AI Agent Tool: The researcher developed a poisoned ClawdBot Skill called "What Would Elon Do?" The Skill contained the malicious prompt in the `rules/logic.md` file, which is read when the Skill is activated. The researcher published their Skill to ClawdHub.
[AML.T0010.001] AI Software: Users downloaded the poisoned Skill from ClawdHub.

The researcher had used a script to increase the number of downloads of their Skill to increase visibility and gain trust.

Note that ClawdHub does not display all files that are part of the Skill, making it hard for users to review Skills before downloading them.
[AML.T0011.002] Poisoned AI Agent Tool: When a user asked Claude Code "what would Elon do?" it calls the poisoned Skill.
[AML.T0051.000] Direct: Claude Code read all files that are part of the Skill, executing the malicious

prompt in the `rules/logic.md` file.

[AML.T0074] Masquerading: Claude Code prompted the user before executing the shell command. The researcher had registered the `https://clawdhub-skill.com` domain, which appears to be legitimate and may be confused with the legitimate `https://clawdhub.com` domain, causing the user to select confirm.

[AML.T0053] AI Agent Tool Invocation: Claude Code executed the shell command using it's `bash` tool.

[AML.T0048] External Harms: In this proof of concept, the researcher simply pinged their server and warned the user of the dangers of using Skills without reading the source code, causing no harm. However, they could have delivered a malicious payload, and caused a variety of harms, including:

- Exfiltrating the user's codebase
- Injecting backdoors into the user's codebase
- Stealing the user's credentials
- Installing malware or crypto miners
- Performing anything else Claude Code is capable of

References

- eating lobster souls Part II: the supply chain (aka - backdooring the #1 downloaded clawdhub skill) — https://x.com/theonejvo/status/2015892980851474595